

Stealc Malware Report

Stealc — Malware Analysis Report

Published: 2026-06-01 | TLP: CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

1. Executive Summary

Stealc is a C-language infostealer sold on underground forums since early 2023. ANY.RUN's current tracker ranked it fourth by recent public task volume. Stealc targets browsers, email clients, messengers, crypto wallets, files, Discord, Telegram, Outlook, and can drop additional malware. Recent 2026 reporting shows Stealc continuing to benefit from fake CAPTCHA and ClickFix-style social engineering.

Stealc infections should be treated as high-risk credential and session-token compromise. The defensive priority is not only removing the binary, but also invalidating stolen cookies/tokens, rotating credentials, reviewing OAuth grants, and hunting for downstream misuse.

2. Sample Metadata

Field	Assessment
Family	Stealc / StealC
Type	Information stealer / downloader
Platform	Windows
Language	C per ANY.RUN family overview
First promoted	Early 2023
Current ranking	#4 on ANY.RUN current tracker; 218 tasks in last seven days shown
Common delivery	Fake CAPTCHA / ClickFix, cracked software, gaming/community lures, fake apps
Confidence	High for family behavior; medium for current infrastructure

3. Source Review & Confidence

Claim	Source	Date	Confidence	Notes
Stealc is an infostealer written in C and promoted on Dark Web forums since early 2023.	ANY.RUN Stealc overview	Accessed 2026-06-01	High	Family overview.
Stealc steals data from browsers, email clients, Discord, Telegram, Outlook, files, and can drop additional malware.	ANY.RUN Stealc overview	Accessed 2026-06-01	High	Capability summary.
StealC rose in March 2026 infostealer telemetry.	Stealed March 2026 report	2026-03-28	Medium	Vendor telemetry, not universal.
Fake CAPTCHA flows delivered StealC in 2026 reporting.	WinBuzzer / LevelBlue-derived reporting	2026-02-20	Medium	Validate with sample.

Claim	Source	Date	Confidence	Notes
Stealc operators and panels have been subject to security research and exploitation.	CyberArk research	2026-01-15	Medium	Threat ecosystem context.

3.1 Expanded Source Matrix

Source	Contribution	Confidence
ANY.RUN tracker and Stealc page	Current ranking, family overview, and sample context.	High
Stealed March 2026 report	Infostealer telemetry and market context.	Medium / High
LevelBlue fake CAPTCHA campaign	Multi-stage ClickFix delivery, compromised sites, active fake CAPTCHA domains, and Stealc/Lumma payload rotation.	High
CyberProof ClickFix campaign	EDR observations, clipboard abuse, injection behavior, and hunting context.	High
SentinelOne ClickFix research	Cross-family ClickFix delivery mechanics and defensive guidance.	High
Netlas fake prompts research	Broad ClickFix growth, fake prompt infrastructure, and trend context.	Medium / High
CyberArk Stealc panel research	Operator ecosystem and backend panel exposure context.	Medium

3.2 Evidence Ledger

Claim	Evidence	Confidence	Analyst Note
Stealc is an infostealer targeting browsers, wallets, apps, and files.	ANY.RUN family overview.	High	Core capability.
ClickFix/fake CAPTCHA delivery is a major current delivery pattern for stealers including Stealc.	LevelBlue, CyberProof, SentinelOne, Netlas, WinBuzzer.	High	Technique spans multiple payload families.
Payload choice may rotate between Stealc, Lumma, and other stealers.	LevelBlue campaign reporting.	Medium / High	Delivery infrastructure may be more durable than payload family.

Claim	Evidence	Confidence	Analyst Note
Stealc panel and ecosystem weaknesses can expose operator-side data.	CyberArk research.	Medium	Useful context, not directly a victim-side detection.

4. Payload Variants and Delivery

Stealc is commonly delivered through social engineering rather than exploit-only paths. Current lures include fake CAPTCHA instructions, copied PowerShell commands, fake software cracks, gaming tools, Discord attachments, Telegram fake applications, and trojanized installers. Operator-hosted PHP panels give affiliates infrastructure privacy and decentralization.

4.1 Ecosystem and Delivery Notes

Stealc is part of the modern infostealer economy: lightweight, credential-focused, affiliate-friendly, and often delivered through social engineering that makes the user perform the execution step. ClickFix is especially important because it bypasses ordinary download suspicion. The victim is told to press a key sequence, paste a command, and run it as part of a fake verification flow.

For defenders, this means Stealc detection should not start at the final binary. It should start at the web-to-clipboard-to-run-dialog pattern, browser-to-shell process lineage, encoded PowerShell, and unexpected credential-store access.

5. Infection Chain Analysis

1. User encounters a fake CAPTCHA, cracked software lure, fake app, or malicious community attachment.
2. Victim runs a copied command, script, or executable.
3. Loader stages Stealc payload.
4. Stealc profiles the host and collects browser credentials, cookies, wallets, app data, files, and messenger/email artifacts.
5. Stolen data is compressed or staged and exfiltrated to operator infrastructure.
6. Additional payloads may be dropped.

6. Technical Analysis

Primary behaviors:

- Browser credential and cookie theft.
- Crypto wallet harvesting.
- Discord, Telegram, Outlook, and email-client data collection.
- File grabbing.
- Persistence and evasion in some builds.

- C2 communication to operator-hosted panels.
- Downloader capability for additional malware.

6.1 Static Analysis Expectations

For Stealc samples, review:

- PE metadata, compiler, packer, and entropy.
- Target lists for browsers, cookies, local state, wallet extensions, Discord, Telegram, Outlook, Steam, and file grabber paths.
- RC4 or other encryption/encoding routines where present.
- C2 panel URLs, endpoint paths, campaign IDs, and exfil formats.
- Screenshot and system-information collection strings.
- Loader/dropper relationship and persistence decisions.

6.2 Dynamic Analysis Expectations

Collect:

- Compromised website or fake CAPTCHA URL.
- Clipboard contents and exact command shown/pasted.
- Browser process spawning `power shell.exe`, `cmd.exe`, `mshta.exe`, or script hosts.
- Downloaded loader and final payload hashes.
- Credential-store and wallet-file access.
- HTTP/S POSTs to panel endpoints and timing relative to file access.
- Screenshots, process injection, and self-delete behavior where observed.

7. Indicators of Compromise

7.1 Indicator Summary

Indicator Class	Count	Confidence	Recommended Use
Hashes	Sample-specific	High	Exact-match sweep from sandbox/intel sources.
Domains/URLs	Campaign-specific	Medium	Hunt and enrich.
Host indicators	Behavioral	High	Primary detection value.
Delivery themes	Fake CAPTCHA, cracks, gaming tools	Medium	Awareness and proxy hunting.

7.2 Host Indicators

Type	Indicator	Confidence	Notes
Process	PowerShell or cmd launched from browser after fake CAPTCHA instructions	High	ClickFix-style delivery.
File access	Browser Login Data, cookies, local state, wallet extension files	High	Credential theft.
App access	Discord, Telegram, Outlook profile data	High	Stealc target set.
Network	POST to rare domain shortly after credential-store access	Medium	Requires process context.

7.3 IOC Usage Guidance

Use Stealc infrastructure indicators only after enrichment because many campaigns rotate domains and hosting quickly. Behavioral detections around fake CAPTCHA command execution, credential-store access, wallet-file access, and suspicious exfiltration are more durable.

7.4 Infrastructure Analysis

Score infrastructure by layer:

Layer	Examples	Defensive Use
Redirect/compromised site	WordPress or legitimate site injection	Web proxy and user-reporting pivot.
Fake CAPTCHA domain	Lookalike verification host	Block/hunt if campaign-specific.
Loader stage	Script or binary staging host	High-value hunt and takedown target.
C2/panel	Stealc exfil endpoint	High confidence if extracted from sample.

8. MITRE ATT&CK Mapping

Technique	Name	Rationale
T1204.002	User Execution: Malicious File	Fake app/crack/attachment execution.
T1059.001	PowerShell	ClickFix copied-command delivery.
T1555.003	Credentials from Web Browsers	Browser password/cookie theft.
T1539	Steal Web Session Cookie	Cookie/session theft.
T1005	Data from Local System	File grabbing.
T1119	Automated Collection	Automated harvesting of app/browser data.
T1071.001	Web Protocols	C2 and exfiltration over HTTP/S.
T1105	Ingress Tool Transfer	Additional payload delivery.

9. Detection Engineering

Sigma - Browser-Launched PowerShell Followed By Credential Store Access

```

title: Browser Launched Script With Infostealer Credential Store Access
id: 5de90965-2c1a-4a9c-b9df-stealc-0001
status: experimental
description: Detects ClickFix-style browser-to-script execution that is commonly used to deliver stealers such as Stealc.
references:
  - https://any.run/malware-trends/stealc/
author: Lost Boys Cyber
date: 2026-06-01
tags:
  - attack.execution
  - attack.t1059.001
  - attack.credential_access
  - attack.t1555.003
logsource:
  product: windows
  category: process_creation
detection:
  selection_parent:
    ParentImage|endswith:
      - '\chrome.exe'
      - '\msedge.exe'
      - '\firefox.exe'
      - '\brave.exe'
  selection_child:
    Image|endswith:
      - '\powershell.exe'
      - '\cmd.exe'
      - '\wscript.exe'
      - '\mshta.exe'
  selection_cli:
    CommandLine|contains:
      - '-enc'
      - 'Invoke-WebRequest'
      - 'iwr '
      - 'curl '
      - 'Start-Process'
      - 'FromBase64String'
  condition: selection_parent and selection_child and selection_cli
falsepositives:
  - Developer workflows and admin scripts launched from browser instructions; tune by user group and known domains.
level: high

```

KQL Hunt

```

DeviceProcessEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~ ("chrome.exe", "msedge.exe", "firefox.exe", "brave.exe")
| where FileName in~ ("powershell.exe", "cmd.exe", "wscript.exe", "mshta.exe")
| where ProcessCommandLine has_any ("-enc", "Invoke-WebRequest", "iwr ", "curl ", "FromBase64String", "Start-Process")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, FileName, ProcessCommandLine

```

YARA - Stealer Credential Target Strings

```

rule MAL_Win_Stealc_Like_Credential_Targets {
  meta:
    author = "Lost Boys Cyber"
    date = "2026-06-01"
    description = "Hunts stealers targeting common browser, messenger, and wallet artifacts"
  strings:
    $b1 = "Login Data" ascii wide
    $b2 = "Local State" ascii wide
    $m1 = "Discord" ascii wide
    $m2 = "Telegram" ascii wide
    $e1 = "Outlook" ascii wide
    $w1 = "wallet" ascii wide nocase

```

```
condition:
  uint16(0) == 0x5A4D and 4 of them
}
```

10. Threat Hunting

Hypothesis: If Stealc is present, a browser-initiated or fake-installer chain will lead to credential-store access and outbound HTTP/S exfiltration.

Hunts:

- Browser spawning shell/script interpreters.
- Recent unknown executables accessing browser credential stores.
- Wallet extension and messenger data access by non-browser processes.
- POST traffic to new or low-reputation domains following credential-store reads.

10.1 Additional Hunt Queries

KQL:

```
DeviceProcessEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~ ("chrome.exe", "msedge.exe", "firefox.exe", "brave.exe")
| where FileName in~ ("powershell.exe", "cmd.exe", "mshta.exe", "wscript.exe")
| where ProcessCommandLine has_any ("-enc", "FromBase64String", "iwr", "Invoke-WebRequest", "curl", "bitsadmin")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, FileName, ProcessCommandLine
```

SPL:

```
index=endpoint (parent_process IN ("chrome.exe", "msedge.exe", "firefox.exe", "brave.exe"))
(process_name IN ("powershell.exe", "cmd.exe", "mshta.exe", "wscript.exe"))
("FromBase64String" OR "-enc" OR "Invoke-WebRequest" OR "curl" OR "bitsadmin")
| table _time host user parent_process process_name command_line
```

11. Triage and Incident Response

1. Isolate host and preserve process/network timeline.
2. Identify all credentials and session tokens accessible from the host.
3. Reset passwords, rotate secrets, revoke OAuth grants, and invalidate browser sessions.
4. Review SaaS audit logs for token replay.
5. Hunt for additional payloads and persistence.

12. Validation and Emulation

Validate fake CAPTCHA detections by simulating browser-to-PowerShell execution in a lab using benign commands. Validate credential-store access detections with controlled file-read simulations, not live malware.

13. Recommendations

Priority	Owner	Timeline	Action
Critical	IAM / SOC	24 hours	Revoke sessions and rotate credentials after confirmed Stealc infection.
High	Endpoint Engineering	7 days	Alert/block browser-to-shell ClickFix chains.
High	Security Awareness	14 days	Train users against fake CAPTCHA and cracked-software lures.
Medium	SaaS Admins	30 days	Monitor token replay and suspicious OAuth grants after infostealer events.

14. References and Refresh Notes

- ANY.RUN Malware Trends Tracker: <https://anyrun.de/malware-trends/>
- ANY.RUN Stealc overview: <https://any.run/malware-trends/stealc/>
- Staled March 2026 Infostealer Report: <https://stealed.io/en/blog/infostealer-threat-report-march-2026/>
- LevelBlue Fake CAPTCHA campaign analysis: <https://www.levelblue.com/blogs/spiderlabs-blog/fake-captcha-campaign-inside-a-multi-stage-stealer-assault>
- CyberProof ClickFix infostealer campaign analysis: <https://www.cyberproof.com/blog/fake-captcha-attack-uncovered-clickfix-infostealer-campaign/>
- SentinelOne ClickFix analysis: <https://www.sentinelone.com/blog/how-clickfix-is-weaponizing-verification-fatigue-to-deliver-rats-infostealers/>
- Netlas ClickFix / fake prompts research: https://netlas.io/blog/fake_prompts/
- WinBuzzer Stealc fake CAPTCHA reporting: <https://winbuzzer.com/2026/02/20/fake-captcha-trick-installs-stealc-on-windows-pcs-xcxwn/>
- CyberArk Stealc ecosystem research: <https://www.cyberark.com/resources/threat-research-blog/un-o-reverse-card-stealing-cookies-from-cookie-stealers/>

14.1 Intelligence Gaps

- Many ClickFix campaigns rotate payloads; attribution to Stealc requires payload confirmation.
- Fake CAPTCHA domains can be short-lived or hosted on compromised legitimate websites.
- Session-token theft impact depends on SaaS controls, conditional access, and token lifetime.
- Public sources may not include complete C2 paths or panel artifacts.